

Cybersecurity Incidents

Incident 1: City Care Clinic (Profile A)

The Patient Waiting Room Trap

On a busy Tuesday morning, a malicious actor enters the City Care Clinic in Mirpur disguised as a regular patient and sits in the waiting room. While waiting, they connect their laptop to the single, shared "clinic-guest" Wi-Fi network. Because this network is shared directly by both patients and internal clinic staff, the attacker runs a simple packet-sniffing program to monitor network traffic. Within minutes, a patient uses the clinic's online appointment booking website. Because this website uses unencrypted HTTP instead of HTTPS, the attacker captures the administrative username and password typed by the receptionist to manage the system.

Using these credentials, the attacker moves laterally across the network and logs directly into the shared reception PC. This computer is running Windows 7, an operating system that has lacked security support and updates since 2020 , and it has no antivirus software installed. Exploiting a well-known, unpatched Windows 7 vulnerability, the attacker gains full control of the machine and locates the clinic's patient records, which are stored insecurely in basic Excel files right on the desktop.

The attacker deploys a destructive ransomware payload onto the reception PC, immediately locking and encrypting all the patient files. To make matters worse, clinic staff routinely pass USB flash drives freely between all three of the clinic's office PCs to transfer daily files. A staff member plugs an infected USB drive into the reception PC and then moves it to the other two Windows 7 computers , instantly spreading the ransomware across the entire facility. Within an hour, every computer screen in the clinic displays a ransom note.

To ensure the clinic cannot recover, the attacker uses information found on the compromised reception PC to break into the receptionist's personal Gmail account. Since this personal email is where the clinic backs up its patient data weekly, the attacker completely deletes all the backup files from the cloud storage. The clinic is left with no patient schedules, no medical histories, and no way to restore their files, paralyzing their medical operations.

Incident 2: FastFreight Logistics (Profile B)

The Silent Supply Chain Hijack

An automated hacking bot scanning the public internet detects that FastFreight Logistics in Chittagong is running an ancient version of WordPress (version 5.2) for its company website, which has been left completely unpatched and outdated since 2021. This specific version contains over 40 severe, known security vulnerabilities with no patches applied. The bot easily exploits a Remote Code Execution (RCE) flaw, allowing human attackers to break through the website and drop a malicious backdoor into the company's internal office network (LAN).

Once inside the internal LAN, the attackers scan the network and discover the Linux GPS tracking server. This critical server is responsible for tracking 20 delivery trucks in real-time as they communicate via an Android driver mobile app. Unbelievably, the server still uses its factory default SSH root password. The attackers log in instantly with root privileges, gain complete control of the tracking software, and rewrite its code. Instead of displaying the trucks' true locations, the server is forced to loop fake, pre-recorded GPS coordinates. While dispatchers in the office think the trucks are safely moving along their standard highway routes, the entire fleet is completely blind, and management has no idea where their high-value cargo actually is.

While the dispatch team is distracted by the chaotic GPS errors, the attackers expand their reach across the unsegmented office network. They target the company's FTP server, which the administration team uses to send monthly payroll files to the external accountant. Because the FTP protocol transmits data completely unencrypted, the attackers intercept the monthly transfer file. In a single sweep, they steal the legal names, exact monthly salary figures, and National ID (NID) numbers of all 50 employees. To complete the breach, the attackers exploit the office's TP-Link network printer, whose admin portal was left wide open to anyone on the LAN, using it as a permanent hidden base inside the company network to monitor future business operations.

Incident 3: Sip n Chat Café (Profile C)

The Tri-Branch Point-of-Sale Collapse

A threat actor browsing through open-source databases finds a public Google Drive folder link belonging to the Sip n Chat Café in Dhaka. Because the folder's security settings were mistakenly configured to "Anyone with link can view" , the attacker downloads a weekly backup of the café's entire customer database without needing to bypass a single password. This stolen file contains the full names, phone numbers, and email addresses of 8,000 loyal customers.

The attacker uses this customer list to craft a highly realistic phishing email disguised as a customer complaint and sends it directly to the café's manager. The manager, working from home, opens the email and clicks a malicious attachment on their personal laptop. Because this personal laptop is used for business email and financial tasks with no separation between personal and work data , the malware successfully steals the manager's saved login cookies for the café's online ordering website.

The online ordering website relies on insecure HTTP, meaning customer card details are already being sent across the web in plain text. Armed with the manager's stolen login credentials, the attacker logs into the website's administrative backend and plants a malicious credit card skimming script into the checkout page. Every time a customer orders food online, their credit card number, expiration date, and CVV code are silently copied and sent to the attacker.

But the attack does not stop online. The café's internal network completely lacks isolation, allowing the compromised manager's laptop to connect directly to the in-store hardware. The attacker leverages this connection to bridge across the shared branch Wi-Fi and target the physical Point-of-Sale (POS) registers across all three branches. These card-swiping machines run Windows XP, an operating system that has received zero security updates from Microsoft since April 2014. The attacker easily exploits a 10-year-old operating system flaw to inject memory-scraping malware directly into the POS registers. As a result, the moment a physical customer swipes their credit card at the counter to pay for a coffee, their financial data is stolen straight from the register's temporary memory, causing a massive, multi-branch compliance failure.

Incident 4: BD Garments Export (Profile D)

The \$500,000 Supply Chain Extortion

At BD Garments Export in Gazipur, all 30 staff members share a single, generic email account (bdgarments@gmail.com) to manage all international business communications. Because the business has no email security, no spam filtering, and no multi-factor authentication (MFA) enabled, a targeted phishing email easily slips into the shared inbox. A hurried employee clicks a fraudulent link, accidentally giving away the email password to an international business email compromise (BEC) syndicate.

The attackers log into the account. Instead of changing the password and locking the staff out, they choose to sit silently and watch. They set up hidden forwarding rules to monitor emails exchanged with major global buyers like H&M and Primark. Over two weeks, the attackers study the company's shipping schedules, contract structures, and invoice formats. When they see that a massive \$500,000 export shipment of garments is completed and the final invoice is ready for submission through the official buyer portal, the attackers take action.

Because multiple staff members share office PCs where they save critical corporate passwords directly inside the Google Chrome browser, the attackers utilize these saved credentials to access the company's bank internet portal. They log in, intercept the pending invoice submission, and secretly alter the factory's bank routing details. They swap the company's real corporate bank account numbers with an offshore mule account controlled by the criminal syndicate, ensuring the \$500,000 payment from the international buyers will be routed directly to them.

To cover their tracks and prevent the factory from noticing the fraud, the attackers decide to completely cripple the company's internal infrastructure. They know that five different staff members share the incredibly weak administrative password "admin123" for the central SAP Lite ERP server. The attackers log into the SAP server using this password and trigger a destructive script that completely wipes out the entire database containing all active garment orders, production inventory tracking, and corporate payroll. Because the server was built as a single machine with absolutely no data backup system in place, the company's entire manufacturing history and operational data vanished instantly. The factory floor grinds to a complete halt, leaving the business facing bankruptcy and severe contract termination penalties from their global buyers for failing to meet mandatory cybersecurity compliance clauses.